GOOGLE AI BUILDER CUP · BFSI: INTELLIGENT RISK, FRAUD & FINANCIAL EXPERIENCES

SafeMeAI

A browser-based fraud shield for Indian banking customers. Paste a message, link, UPI ID or notice, or answer six questions during a suspicious call, and get a plain answer in English or Hindi. Gemini on Google Cloud reasons about the hard cases; rules and live evidence keep it honest.

LIVE PROTOTYPE
https://safemeai.in

PUBLIC REPO
github.com/rps011/safemeai-portal-public

Problem statement: BFSI - Intelligent Risk, Fraud & Financial Experiences

Runs on Cloud Run, Firebase Hosting, Vertex AI

THE PROBLEM

Fraud now reaches people through their phone, in their language, in minutes

India moves more than 10 billion UPI payments a month (NPCI public data). Scammers follow the money.

- **Social engineering beats technology.** Fake "KYC blocked" SMS, forged .gov.in and bank links, UPI collect-request traps, and "digital arrest" video calls pressure people into sending money or an OTP themselves.
- **Victims decide in seconds, alone.** Official advice (RBI, I4C 1930 helpline, cybercrime.gov.in) exists but is not at hand at the moment of the call or the click.
- **Tools are English-first and rule-bound.** Real scams arrive in Hinglish, Hindi and mixed script, with no trigger words, and a lookalike domain may not exist yet in any blocklist.

Our target: a check a person or a bank can run in seconds, that says what is wrong, why, and what to do next, and that never pretends to be sure when it is not.

No statistics beyond the NPCI scale figure are quoted here on purpose. See slide 10 for our own measured results.

WHO IT HELPS

Citizens at the moment of doubt. Banks as a second line of defence.

CITIZENS

Anyone with a phone and a browser. Nothing to install, English and Hindi, plain-language verdicts, a 1930 call button, and no OTP or PIN ever requested.

BANKS / FINTECHS

A documented API (OpenAPI, batch endpoint, API keys) to score messages and links shown to customers, with an audit trail and explainable reasons. Pilot path on slide 14.

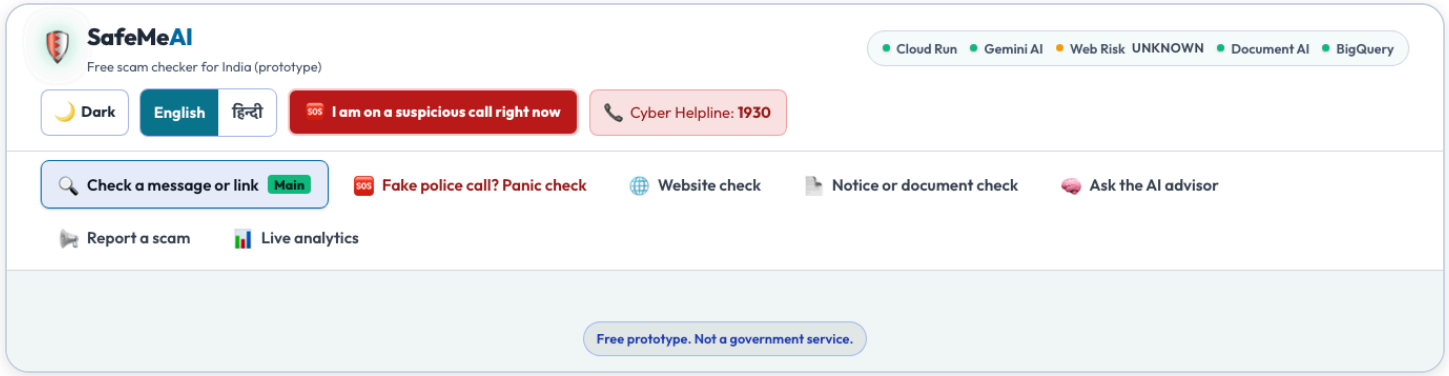
1 · DOUBT
Gets an SMS, link, call or notice that feels off

2 · PASTE OR TAP
Message, link, UPI ID, photo of a notice, or 6 panic questions

3 · VERDICT
Risk level, the evidence found, and what to do now

4 · ASK
Gemini advisor answers follow-ups in Hindi or English

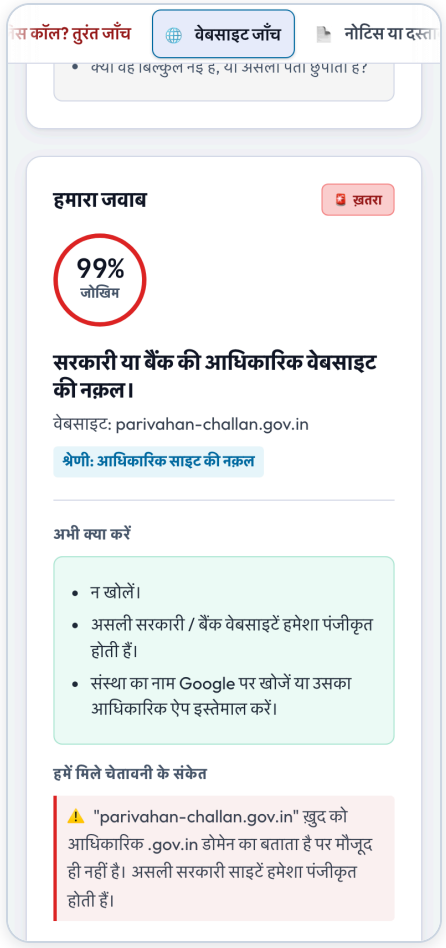
5 · ACT
Call 1930, report on cybercrime.gov.in, or tell the bank



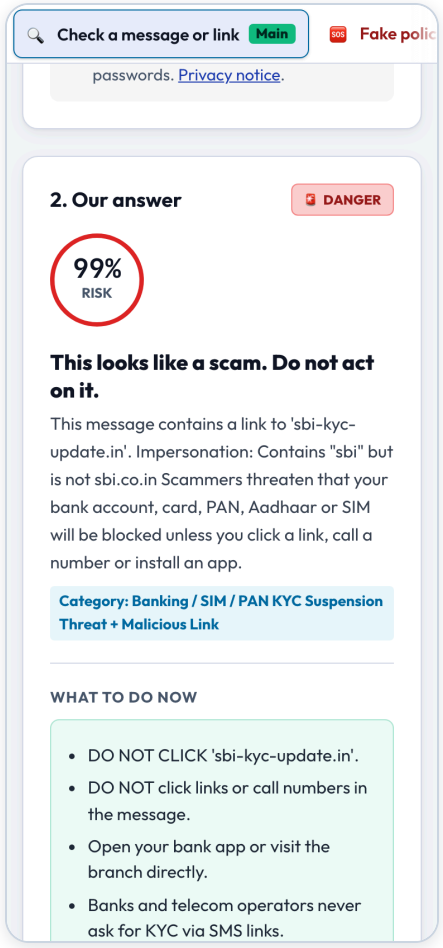
Live home screen, laptop 1366x768, light theme.

THE SOLUTION AT A GLANCE

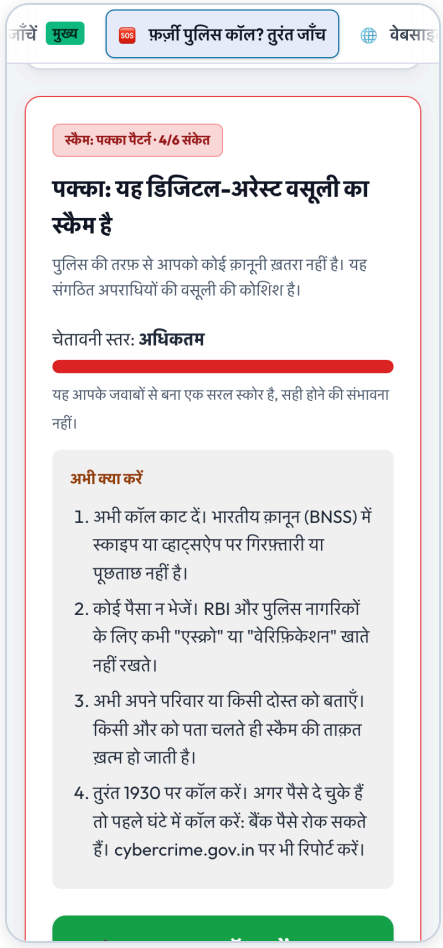
One site, five ways to check. All screenshots are the live product.



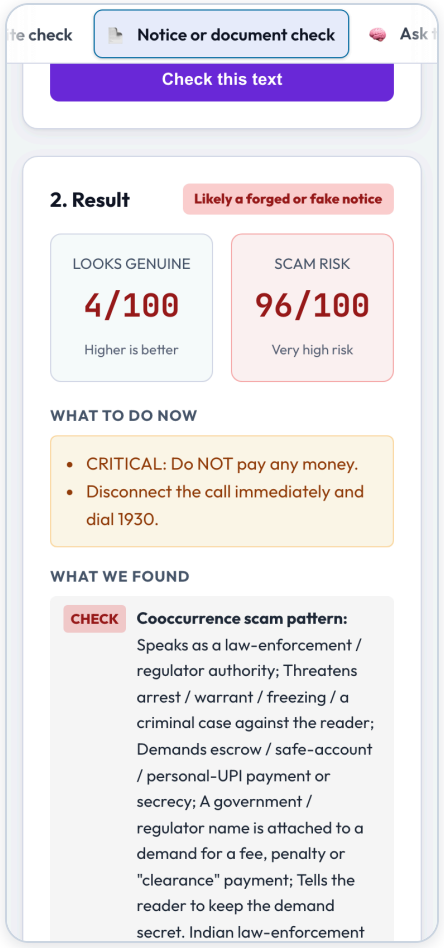
Forged .gov.in site
99% risk, Hindi UI



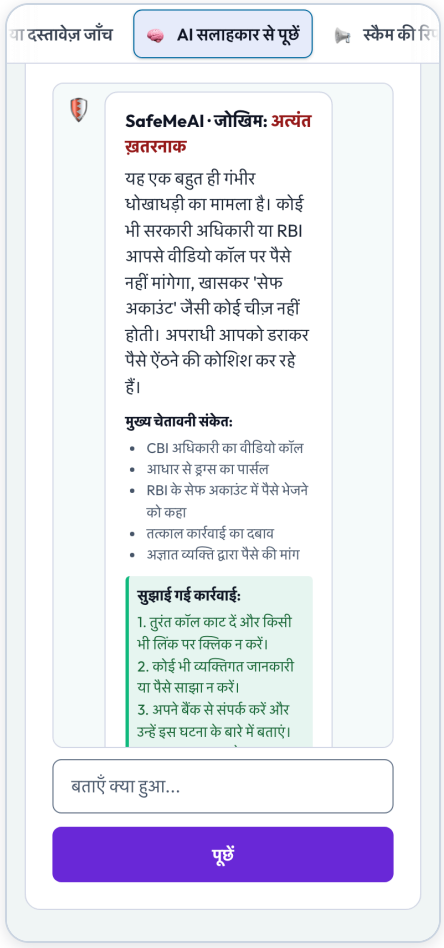
Hinglish KYC scam
Critical 99, reasons shown



Panic check
6 taps, graded level, Hindi



Notice photo
Document AI OCR, then triage

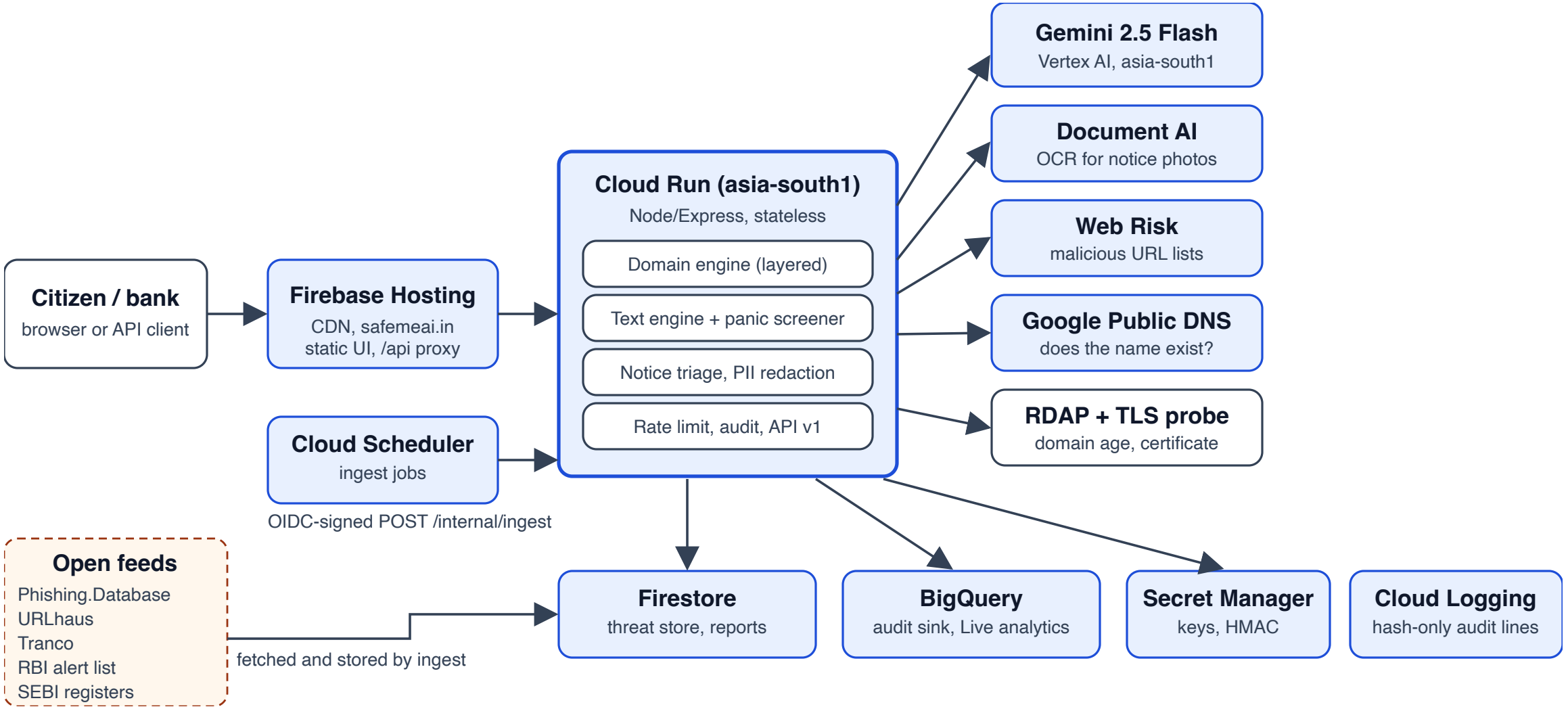


Gemini advisor, Hindi
Reasons, signals, next steps

Captured from https://safemeai.in on 16 Oct 2026, phone 390x844, light theme. The "Live analytics" tab is on slide 11.

ARCHITECTURE

Stateless Cloud Run engine, Gemini on Vertex AI, live threat data



Blue = Google Cloud services in the live deployment. Dashed = external open data. Source: README.md, docs/hosting.md, /api/system/status.

HOW GEN AI IS USED

Gemini reasons about the hard cases. It does not get the last word.

What Gemini does (Gemini 2.5 Flash, Vertex AI, asia-south1)

- **Second opinion** on ambiguous scores (30-70, and low scores that carry a concrete ask) for messages and suspicious domains.
- **Hindi / English advisor**: structured JSON (risk, signals, reasoning, action), schema-validated.
- **Translation** of verdict text to Hindi, as the last step.

What Gemini does NOT do

- Never marks an unverified domain as safe.
- Can raise risk only when the text has a concrete signal (link, number, payment or credential ask). Can lower it only if every signal is purely stylistic.
- Never sees the user's phone, Aadhaar, PAN, card, e-mail, UPI ID or OTP-like codes: redacted before the call.

Guardrails: user text is quoted as untrusted data (prompt-injection resistant) · 4 s hard timeout, fails open to the rules verdict · every response labels its engine ("Gemini live" vs "rules fallback") · output validated before use.

Source: lib/textAi.js, lib/geminiAdvisor.js, lib/redact.js, README.md.

LAYERED VERIFICATION ENGINE

Evidence first: "does it exist, who owns it, is anyone reporting it?"

#	Layer
1	Official namespaces (.gov.in, .bank.in) count only if the name **exists** in DNS
2	Domain age (RDAP)
3	Google Web Risk
4	Threat feeds + RBI/SEBI lists (522k indicators)
5	Lookalike / homoglyph / brand-as-subdomain
6	Live TLS certificate audit (SSRF-guarded)
7	Gemini second opinion (escalate-only)

LIVE EXAMPLE

`parivahan-challan.gov.in`

Verdict: **FORGED OFFICIAL DOMAIN, CRITICAL 99**. It claims .gov.in but does **not exist** (NXDOMAIN). Real government sites are always registered. Gemini added a plain-language explanation.

CONTRAST

`www.sbi.co.in` is allow-listed *and* resolves in DNS: VERIFIED OFFICIAL, score 0. Unknown names are never "safe by default"; failures show "could not verify".

Verdicts re-checked live on 16 Oct 2026. Source: lib/domainEngine.js, README.md.

INDIA-SPECIFIC

Built for Indian fraud, not translated from somewhere else

7,843

SEBI-registered brokers, research analysts and advisers, loaded as allow-lists. 188 RBI Alert List entries (unauthorised forex platforms) plus 9 RBI-authorised platforms.

English + Hindi

Full Hindi UI and advisor. Scam text engine reads Hindi, Hinglish, mixed script and some obfuscation (leetspeak, Cyrillic homoglyphs).

6 taps

Digital-arrest panic check: deterministic graded warning level from six yes/no questions; one "yes" already means hang up and call 1930.

- UPI-specific traps: collect-request "refunds", QR "receive money" tricks, UPI ID and phone lookups against known indicators.
- Advice maps to Indian channels: 1930, cybercrime.gov.in, the bank's own app; IT Act s.66D reference on impersonation.

Counts from /api/analytics/threat-intel on 16 Oct 2026. Source: README.md, tests/panic.test.js.

Minimise data, label uncertainty, harden the edges

- **Privacy notice** in the UI and a DPDP-oriented design (hash-only audit, purpose limitation). Not legal advice; open items are listed in the repo.
- **Data in India**: Cloud Run, Firestore, BigQuery, Gemini and the Document AI OCR processor all run in asia-south1 (Mumbai). Only domain names (never the message) go to public DNS, RDAP and Web Risk.
- **No raw input stored.** Audit rows hold a SHA-256 of the input and an HMAC of the client /24 network.
- **PII redacted** before any Gemini call.
- **Abuse resistance**: token-bucket rate limits per route group, 64 KB JSON and 5 MB upload caps, file-type allow-list, temp-file deletion.
- **Web hardening**: SSRF guard on TLS probes, CSP without inline scripts, HTML-escaped output, HSTS, same-origin CORS.
- **Crowd reports** are scored on independent corroboration plus engine evidence, with reporter reputation; reports against allow-listed, government or well-established domains always go to human review and can never auto-block them.
- **Fail closed**: any network failure reads "could not verify".

Source: README.md, docs/audit.md, lib/redact.js, public/privacy.html.

EVALUATION (INDEPENDENT, BLIND, REPRODUCIBLE)

Honest results on 253 fresh items, production with Gemini on

Set	n	Recall, 95% CI	False-alarm rate, 95% CI	Precision
Messages	150 (70 scam / 80 genuine)	**82.9%** [72.4-89.9]	**10.0%** [5.2-18.5]	87.9%
Domains	79	100% [89.8-100]*	4.4% [1.2-14.8]	94.4%
Notices / documents	24	**33.3%** [13.8-60.9]	0% [0-24.3]	100%
Pooled	253	82.8% [74.9-88.6]	7.3% [4.0-12.9]	90.6%

What Gemini adds (messages): consulted on 9 of 150; +3 true positives, -1 false alarm, 0 regressions. Pooled F1 84.5 to 86.5 vs rules-only. Tiny sample (n=9): directional, not statistically proven. Gemini timed out or was rate-limited on 5 further cases and fell back to rules.

KNOWN GAPS AND FIX PLAN

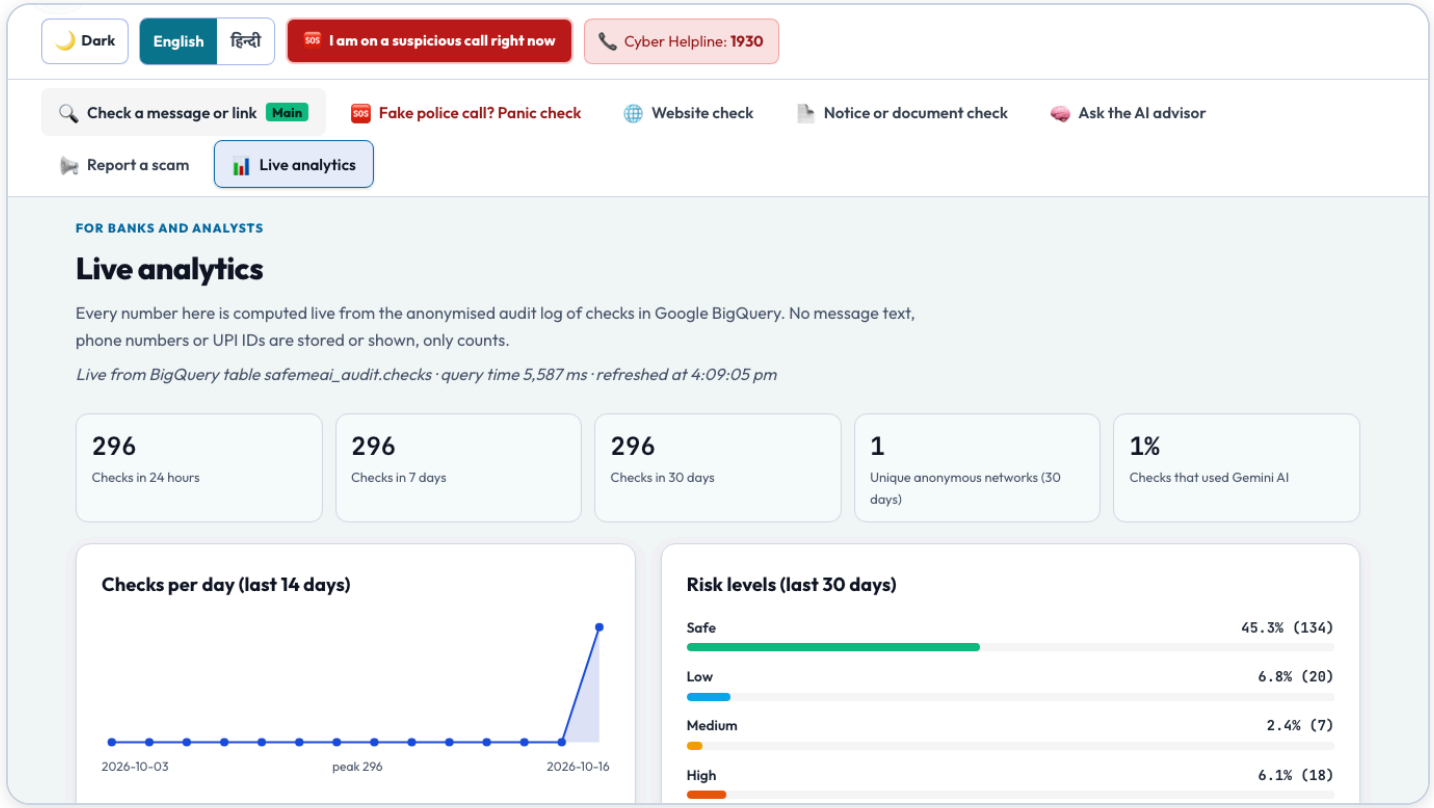
Weak: forged notices (8 of 12 missed), 12 of 70 scams rated below MEDIUM, 8 of 80 genuine alerts flagged HIGH+ (link floor, "UPI PIN changed" style alerts), letter-spaced obfuscation, www-only sites. Fixes are targeted at these classes and must be re-measured on a new unseen set; v2 is now burned.

*Domain recall only shows brand-pattern and non-existent-name detection; no clean-looking live zero-day phishing domain was tested. v1 (88.3% / 13.3% on messages, 50% documents) used a different, older set: **v1 vs v2 is not apples-to-apples**. Set written by an LLM; hard cases over-represented, so these are not field rates.

Source: docs/EVALUATION_V2.md, tests/eval/v2/ (dataset SHA-256 frozen, raw responses included).

REAL ANALYTICS FROM BIGQUERY

Every figure is computed live from the audit table, never invented



- Parameterised BigQuery queries over `safemeai_audit.checks`: checks per day, risk mix, endpoint mix, latency p50/p95, top verdicts.
- Snapshot on 16 Oct 2026: 296 checks in total, 45.3% rated Safe, 1% of checks used Gemini. Counts keep growing as we test.
- **These numbers come from the prototype's own test and evaluation traffic, not real customers.**

Hashed inputs only; 100 MB billing cap per query; 60 s cache. Source: /api/bigquery/analytics.

ENGINEERING QUALITY

Tested, documented, auditable

1,081
tests passing
`node --test`, 0 failures (16 Oct 2026)

OpenAPI
/api/v1/openapi.json, versioned routes, batch of up to 20, optional API keys

Audit
one JSON line per check: input hash, verdict, latency, engine; BigQuery sink

- Suites cover domain engine, text engine, accuracy regressions, panic screener, Hindi/i18n coverage, ingest, rate limits, analytics, client-IP trust.
- Evaluation harness with frozen dataset hashes and raw per-case responses, so any reviewer can re-run it.
- Truthful status page: `/api/system/status` reports real service health, not a green light by default.

Tests were run from the repo with `node --test` on 16 Oct 2026. No hosted CI service is claimed.

SCALABILITY AND FEASIBILITY

Serverless by design; cost is dominated by the few Gemini calls

- **Stateless Cloud Run** autoscales on request load; threat data is an in-memory index (O(1) lookups) refreshed from Firestore, so no datastore call per check.
- **Cheap path first:** rules answer most checks in milliseconds; Gemini is consulted only on ambiguous ones (9 of 150 in our evaluation).
- **Known limits:** rate limits are per instance (Cloud Armor recommended for a global cap, not enabled); scale-to-zero means occasional cold starts.

Cost sketch (ESTIMATE, not a measured bill)
Assume ~600 input + ~200 output tokens per Gemini call at the public Gemini 2.5 Flash list price (about US$0.30 / US$2.50 per 1M tokens): roughly US$0.0007 per call. If about 6% of message checks consult Gemini, that is roughly **US$0.04 per 1,000 message checks** for Gemini. Cloud Run compute, Web Risk and Document AI (per page) are extra and small at pilot volumes; confirm against the current Google Cloud price list.

Source: README.md (architecture, SLO targets), docs/api.md, docs/EVALUATION_V2.md. Prices change; estimate labelled accordingly.

BUSINESS VIABILITY AND BANK-PILOT PATH

Start in shadow mode: prove value before touching a customer

PHASE 1 · SHADOW
Bank sends customer-facing messages and links to the API; SafeMeAI scores silently. No customer impact.

PHASE 2 · MEASURE
Compare against the bank's confirmed fraud cases. Agree a false-positive budget before anything is shown.

PHASE 3 · ASSIST
Warnings in app or SMS banners for high-confidence verdicts only.

- **Interface ready:** API keys with a pilot tier, batch scoring, audit trail with input hashes. SLO *targets* (not guarantees): 99.9% availability, text p95 < 800 ms, domain p95 < 4 s.
- **Before any commercial launch:** confirm licences for the Tranco and URLhaus feeds, replace or license OpenPhish (currently not used), finish the DPDP checklist (DPO, breach runbook, processor agreement).
- **Honest status:** a prototype. No customers, pilots or revenue to report.

Source: docs/api.md, README.md (licence table, SLOs, DPDP notes).

ROADMAP

Future work (not built, not part of this submission)

FUTURE

Vertex AI Search over RBI / NPCI circulars so advice cites the actual rule. (Today's compliance search is static curated citations.)

FUTURE

Pub/Sub event pipeline for bank telemetry and report streams. (Today's telemetry ingest is a simulated acknowledgement.)

FUTURE

Trained classifier on human-confirmed reports, evaluated on a larger consented, independently labelled set.

FUTURE

Real-time device integrations (SMS and link warnings) with the user's explicit consent.

Marked future work so nothing here is mistaken for a live feature.

What is, and is not, part of this submission

- **Built for this hackathon:** the SafeMeAI web platform (portal, API, engines, evaluation), built 14-16 Oct 2026, inside the 7 Sep - 18 Oct 2026 window.
- **Not part of this submission:** SafeMeAI also has a separate, earlier Android app. It is not submitted and not judged. (27 seed domains were ported from it as first-party data and are labelled as such in the threat store.)
- **Team:** Rana Pratap Singh (GitHub: rps011).

Live prototype: https://safemeai.in

Cloud Run: safemeai-bfsi-846801666760.asia-south1.run.app

Public repo: github.com/rps011/safemeai-portal-public

Contact: support@safemeai.in